

• Network Scanning (The Penetration Guy)

~~04~~ = Scanning & Enumeration

*CEH PRACTICAL COMPLETE COURSE & EXAM 2023 (unofficial)

*I/ video Nmap Part 2

⑧ ~~nmap~~ nmap -iL (input.txt) ← file Name
type website in it

nmap -iL (input.txt) ← for scanning website put the website in txt file

⑩ Here -sS flag is used for TCP SYN scan, which is a stealthy and efficient method of scanning for open port on a target system.

nmap -sS <Domain Name>

⑪ Here "-oG" flag can be used to store the nmap result in to specific file.

nmap -sS <Domain Name> -oG <file-path>

[eg:- nmap -sS www.google.com -oG nmap-result]

- (12) The "-sU" flag is used with nmap to perform a UDP scan, which allows the user to discover open UDP ports & services on a target system.

```
nmap -sU <Domain Name>
```

- (13) The "-sn" flag is used with nmap to perform a ping scan, which sends ICMP requests to a target host or network to determine hosts is up or not.

```
nmap -sn <Domain Name>
```

- (14) The "-p" flag is used with nmap to perform scan on a specific port or range of ports (in our case it will scan port 80, 443 & 21).

```
nmap -p 80 443 21 <Domain Name>
```

```
[nmap -p 80 443 21 www.geeksforgeeks.org]
```


- (15) We can also specify the range of ports to scan on a network (In this case it will scan all the ports in the range of 1 to 80)

`<env> nmap -p 1-80 - <Domain Name>`

- (16) Here -A indicates aggressive - it will give us extra information like OS detection (-O), version detection, script scanning (-sC), and traceroute (-tracert). It even provides a lot of valuable information about the host.

`nmap -A <Domain Name>`

- (17) Using this command we can discover the target hosting service or identify additional targets according to our needs for quickly tracing the path.

`nmap --trace out <Domain Name>`

~~(18)~~

(18) Here it will display the operating system where the domain or ip address is running but will not display the exact operating system available on the computer. The command will just guess the running operating system (OS) on the host.

`nmap -O <Domain Name>`

* → (19) ~~Pr~~ commands told to skip the process where to check whether the host is alive or not (i.e. ICMP ping send if the host is live as assume but if the host does not response to the ping then the nmap assume its offline & skip scanning it).

However we use `-Pn` command then nmap assume the host in the target list are online & directly checks them without checking the availability first.

`nmap -Pn <Domain name>`

I> Video Remote Desktop Protocol

*> RDP Port No = 3389

→ Open the RDP by giving I.P, User name & password after that type the ipconfig for ip & type net user to know the users present in

I> Video Finding the IP Address & Using Netdiscover

RDP in the network

→ Linux (Ubuntu / or Kali Linux / Parrot any debian disro = ifconfig (for ip address)

→ Windows = ipconfig (for ip address)

• Netdiscover is tool used for gathering information related to ip, subnet, ports many other things etc. But Netdiscover is slower than Nmap.

For finding I.P subnet we will use Netdiscover

netdiscover -r < i.p address >

But if we don't know the subnet then, put

netdiscover -r 192.168.77.0/24

↑
use this

I/ Video Nmap Part 1

sent in
ROP in
the network

Nmap is Linux Command-line tool for network exploration & security auditing. This tool is generally used by hackers & cybersecurity enthusiasts & even by network and system administrators. It is used for the following purpose.

- Real time information of a network
- Detailed information of all the IPs activated on your network.
- Number of ports open in a network.
- Provide the list of live hosts.
- Port, OS & Host Scanning.

→ In case of Debian / Ubuntu

`sudo apt-get install nmap`

→ In case of CentOS / RedHat

`yum install nmap`

① To scan a system with Hostname and IP address. First, scan using Hostname.

```
nmap www.geeksforgeeks.org
```

[It will tell which ports are open & close. Also mention its I.P address]

Now Let's scan using IP Address

```
nmap < I.P address >
```

② To scan using "-v" option

```
nmap -v www.geeksforgeeks.org
```

It is used to get more detailed information about the remote machines.

If we use "-vv" double verbose which helps to get more detailed information

③ To scan multiple hosts

```
nmap 103.76.228.224 157.240.198.35  
172.217.27.174
```

We can scan multiple hosts by writing IP addresses or hostnames with nmap.

④ To scan whole subnet

```
nmap 103.76.228.* [103.76.228.0]
```

We can scan a whole subnet or IP range with nmap by providing "*" with it. It will scan a whole subnet and give the information about those hosts which are up in the network.

⑤ To scan specific range of IP address

```
nmap 192.168.29.1-20
```

We can specify the range of IP addresses. This command will scan IP address 192.168.29.1 to 192.168.29.20.

⑥ To scan to detect firewall settings.

```
sudo nmap -sA 103.76.228.244
```

Detecting firewall settings can be useful during penetration testing and vulnerability scans. To detect it we use "-sA" option. This will provide you with information about firewall being active on the host. It uses an ACK scan to receive the information.

⑦ To Identify Hostnames

```
sudo nmap -sL 103.76.228.244
```

We use "-sL" option to find hostnames for the given host by completing a DNS query for each one. In addition to this "-n" command can be used to skip DNS resolution. While the "-R" command can be used to always resolve DNS.

05 - Hacking Web Application

IP Wpscan & Metasploit

Wpscan is a WordPress security scanner used to test WordPress installations & WordPress - Powered websites. This is a command line tool used in Kali Linux. This tool can be used to find any vulnerable plugins, themes, or backups running on the site. It is usually used by individual WordPress site owners to test their own websites for vulnerabilities and also by large organizations to maintain a secure website. This tool can be used for enumerating users & perform brute-force attack on known WordPress users. In this article we will discuss different commands of wpscan tool, the most commonly used attacks on WordPress site & tips to defend against them. The below functionalities of this tool can be used from the point of view of a hacker or even just someone who wants to test if their WordPress site is secure enough.

Wpscan is usually pre-installed in Kali - Linux. ~~Otherwise~~ It

Wpscan Commands :

① -url : (basic scan)

The following command performs a vulnerability scan of the entire wordpress site scanning for any vulnerable plugins, themes and backups.

② -help : (help options)

command : `wpscan --help`

It is used to get the complete list of the usability of the tool using different switches for different functionalities -

③ -c u : (Enumerating website users)

command : `wpscan -url IP-ADDRESS-OF-WEBSITE -c u`

This command lets the wpscan tool enumerate the WordPress site for valid login usernames. After scanning it gives all the usernames the tool has enumerated which are valid users of the WordPress site often times brute forced to gain unauthorized access to the WordPress admin / author dashboard.

④ For find password for the user

Use command :-

wpscan --url (website) --usernames [path address] --password [path address]

• We can Also Use Brute force

wpscan -u http://10.10.10.10:8080/New -u root
-P passwdfile.txt (Use this only after enumerating)

wpscan --url http://10.10.10.10:8080/New --usernames
userlist.txt, --passwords passwdlist.txt

NOTE :- IF BRUTE FORCE
DOESN'T WORK

WE CAN USE

MSF (CONSOLE
[METASPLOIT])

Then type `msfconsole` to
open `metasploit`. type

TYPE = ① use `auxiliary/scanner/http/wordpress-
login-brute`

② show options

③ set `PASS_FILE` /directory

④ set `RHOSTS` [IP] [target ip
mention]

⑤ set `RPORTS` 8080 [target port]

⑥ set `TARGET_URI` `http://10.10.10.10:8080/`
[target[↑] ip & port[↑]]

⑦ set `USERNAME` admin

OR

Use

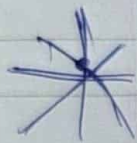
- ① use auxiliary / scanner / http / wordpress_login_enum
- ② set hosts [I.P.]
- ③ set user-file (directory)
- ④ set pass-file (directory)
- ⑤ run

If shows error like [/ does not seem to be Wordpress site]

Then type

- ⑥ set upcheck
- ⑦ set upcheck false
- ⑧ run

[Website :- free codecamp-org (how to use ^{hydra} pentesting tutorial)]



Hydra

Hydra is a Brute - forcing Tool.
Burpsuite is also been used as Brute-force tool. But Hydra is used in ~~EDP~~ practicals for cracking FTP credentials.

① \$ Hydra -h

[List out all the functions of it]

→ How to perform a Single Username / Password Attack with Hydra

• Here its Syntax:

\$ Hydra -l <username> -p <password> <server> <service>

Assume we have user named "molly" with a password of "butterfly" hosted at 10.10.137.76. Here is how can we use Hydra to test the credentials for SSH.

\$ Hydra -l molly -p butterfly 10.10.137.76 ssh

→ How to Perform a Password Spraying Attack with Hydra.

What if we know a password that someone is using, but we are not sure who it is? We can use a password spray attack to determine the username.

A password spray attack is where we use a single password & run it against a number of users. If someone is using the password, Hydra will find the match for us.

This attack assumes we know a list of users in the system. For this example, we will create a file called `users.txt` with the following users:

<service>

Eg:

root

admin

user

molly

steve

richard.

Now we are going to test which user has the password "butterfly".


```
$ hydra -l users.txt -p butterfly 10.10.137.76 ssh combi
```

[Note: We have used the flag L instead of -l; -l is for a single username & L is for a list of usernames.

→ How to Perform a Dictionary Attack with Hydra

A dictionary attack is where we have single / multiple usernames and we provide a password wordlist to Hydra. Hydra then tests all these passwords against every user in the list.

We are going to use the Rockyou wordlist for this example along with the users.txt file we created in the previous attack. If you are using Kali Linux, you can find the RockYou wordlist under `/usr/share/wordlists/rockyou.txt`

Here is the command.

```
$ Hydra -L users.txt -P /usr/share/wordlists/rockyou.txt 10.10.137.76 ssh
```

If this attack is successful, we will see a similar result to the other two commands. Hydra will highlight the successful username/password.

Then you find

★ → How to Crack credentials for FTP.

[Hacking Web Server] ← (Github Repository)

- Crack FTP credentials using nmap

command $\rightarrow$ `nmftp -p { 21 10.10.10.10` (check if it is open or not)

$\uparrow$ $\uparrow$

FTP port I.P

If port is running i.e. FTP services
is running on it.

command $\rightarrow$ `ftp 10.10.10.10` (To see if it is directly connecting or needing credentials)

After hitting enter it will ask for username & password i.e first username then password.

Then go to Desktop and in Cch tools folder you will find wordlists, here you will find usernames & passwords file.

$\left[\begin{array}{l} -L \rightarrow \text{If Don't Know Username specific or to check all username} \\ -l \rightarrow \text{If You know the specific username \& finding the password} \end{array} \right.$

Now in terminal type

command $\rightarrow$

```
hydra -L /home/attacker/Desktop/CEH-TOOLS/wordlists/username.txt  
-P /home/attacker/Desktop/CEH-TOOLS/wordlists/Password.txt  
ftp://10.10.10.10
```

```
hydra -l user -P password.txt ftp://10.10.10.10
```

[After getting the USERNAME & Password]

- ① Now go to Windows Command Prompt.
- ② Write FTP (IP)
- ③ Write get secret.txt
- ④ You will get a secret file
- ⑤ Now your FTP challenge will be complete.

* Note:

http

\$ hydra

Here we have given small
Because we know username &
password both.

\$ hydra -l user

user

all username to find the password matching }
& finding the particular password for it

Bitten Hydra

[Password Cracking with Hydra]

Sl Wordlists / username.txt

Password.txt

* Note :- for practicing Brute force use this site.

<https://attack-samsclass.info/brute.htm>

\$ hydra -l root -P password attackdirect.samsclass.info http-get /brute/

↑
username

Here we have given small 1 & P
because we know username & password both.

\$ hydra -l root -p password attackdirect.samsclass.info http-get /brute/

↑ ↑ ↑ ↑

username original password website targeting http server service

- Bruteforcing attack direct `samsclass.info` with `rockyou.txt` (In this we have username & taking help from password Wordlist `rockyou.txt`)

command → `$hydra -l root -P /root/Downloads/rockyou.txt attackdirect.samsclass.info http-get /brute0/`

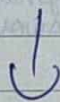
• The username is there; root, admin, administrator

The password is a three-digit PIN.

given in question:

root@kali: ~ /brute # hydra -L 3names -x 2:2:a attack.samsclass.info http-get-form "/brute4.php :login='^User' & pass='^PASS': Deny"

The Given Command Should be



① First make a `username.txt` for root, admin, administrator.

command → `cat > usernames.txt`
 root
 admin

* Hint: - hydra -l (Username) (website) http-get-form &
"/(login page url after /) : (login page requirement user or login)
= ^USER^ & (pin or password as required & mention in page)
= ^PASS^ & (mention failed response eg Denied)
administrator.

② Then type command

→ hydra -L /root/ usernames.txt -x 3:3:1

attack.samsclass.info http-get-form

"/brute4.php : login = ^USER^ & pin = ^PASS^ : Denied'

class.info

• THM ROOM [Windows Priv Esc]

① Checking the port

command → nmap -T5 -Pn -vv (i.p)

After getting the output we can target
port 3389 & 445; with the help of hydra
we try to bruteforce 3389 port.

attack.

We will check by giving the command
hydra -l user -P (path or text file).
After getting the password we will put the
command which was already there in
Room (Windows Priv Esc) & gain
access to the RDP.

06 - Hacking Android Mobile Platforms

① Discover Android Machine's IP & Port.

[Using Nox Player]

• Android software (Nox Player)

- ① `nmap ip -sv -p 5555` [Scan for adb port]
- ② `adb connect IP: 5555` [Connect adb with parrot]
- ③ `adb shell` [Access mobile device on parrot]
- ④ `pwd --> | s --> cd sdcard --> cat secret.txt`
[If you can't find it there then go to Downloads folder using: `cd downloads`]

Use `(cd ..)` for going back

07 - Steganography

Date _____
Page _____

* Using Snow Application.

① Download snow application from
(darkside.com.au/snow)

② Rename the application name
from SNOW to snow.

③ Use command [directly on the directory]
[snow -c -m "My swiss account
number is 121212121212" -p "magic"
readme.txt readme2.txt]

Here -m = message.

-p = password.

readme2.txt = secret is stored with readme.txt content

readme.txt = In this file i am putting any
value or information which will
be after used by readme2.txt with
the secret information.

④ Use Command to know the password
stored in the text file.

[snow -c -p "magic" readme2.txt]

08 - Cryptography

• ① Tool = Hash Calc

→ Gives MD5, SHA1 & CRC32 & many others.

• ② Tool = Veracrypt

[Very famous tool for disc encryption]

① First click on Create Volume

- Create an encrypted file container
 - Standard veracrypt volume
 - Volume location (click on Select File > Desktop > File name > Create file)
 - Encryption option (as it is)
 - Volume size (in only mb for file)
 - Create a short password.
 - Click ok after file made & then click exit.

After the file made we can't directly select the file so we need to create a mount.

② To Create a Mount

- Select any other drive (like volume 1)
- Then click select files (select the folder in desktop)
- Select the option mount it will ask for password.

(like L drive)
→ Select any other you want

- ↳ check the file manager we will see the new drive.
- ↳ Put any text file which has some written thing in the folder we made.
- ↳ Then unmount it & it will disappear from This PC & close the VeraCrypt.

③ After it click on VeraCrypt to see the folder which has file.

- ↳ Select any other drive (like first selected & so selected any other than L)
- ↳ Then click select files
- ↳ Then select the folder.
- ↳ It is ask for password; put it.
- ↳ Then click on OK.
- ↳ After this click file manager; then open the Drive; open the folder & then click on the text file you will see the message in it.

Create file

(like L drive)
↳ Select
any other
you want

• (3) Tool = Cracking Hashes

i) We can either use hashes.com or crackstation.net

ii) Put the hashes & then decrypt it.

• (4) Tool = BC Text Encoder

i) We have to give a value like something written etc so it will encode it & then we have to decode it to get the same encoded answer.

• (5) Tool = Cryptool (Part-1) (RC4)

i) First click on new & type message in it.

ii) Click on encrypt / Decrypt ---> Symmetric (modern)
---> (RC4) ---> Key length (14) & then click on encrypt.

iii) Ctrl + S & save it on desktop.
(save changes to orig. org? -> no)

iv) Click on open in that tool only.

v) Select the file by changing from Text file

to All files.

vi) Click on Encrypt & Decrypt (In exam the file will be given & also which method to do like RC4, RC2 will be given)

vii) Select Symmetric (modern) ---> RC4 ---> Key length 14 ---> Decrypt.

viii) We will see the original file which contains the message.

⑥ Tool = Cryptool (Part-1) (ECB)

~~i) Same with step (v) of RC4.~~

i) As earlier the files will be given.

ii) Open the file from the open option & select it.

(modern) iii) Click on Encrypt / Decrypt ---> Symmetric (modern) ---> DES (ECB)

---> if password is given then put it if not then directly click on Decrypt.

iv) Then you will be able to see the content.

• If there is mention about the FTP in question the will decrypt will get answer as we will

be mention in the question.

type FTP (I.P)

Type username & password.

Type the commands (like ls, get flag.txt)

(222) (1-10-19) (1-10-19) (1-10-19)

09 - SQL injections

① * Authentication Bypass

- ① Select the username.
- ② Add ' -- after the username to bypass the login.
- ③ In password we can type or write whatever.

→ * Note : Refer the github sql injection commands to know the payloads.

② * Auth Bypass Using SQL injection & Exploiting IDOR (Exam Question)

- ① In Exam if CREDENTIALS are GIVEN
for eg :- `www.moviescope.com (sam:test)`
we can directly login.

But

In Exam they will not give username & password.

② If not given username & password then
In username put = sam 'OR' 1=1--

↑
whatever
can be name
given.

[Password = can be whatever we can type]

Q7 In exam if ask for mobile no. or email id it will take time if we perform SQL Injection. [30 mins]

There are 2 ways.

① SQL Maps where we have to write commands takes 30 mins ; & might be complicated.

[If we have to use this then go to github repository & write the command & put the value]

② We can exploit another vulnerability IDOR (Insecure direct object reference) is a type of vulnerability in which web applications an attacker can authorize, delete, access, modify an unauthorized data by manipulating direct object reference such as id, another other number, URL's,

form in the application.

TOOR occurs when application does not properly check user permission & authentication before accessing or modifying data related to a specific object or entity.

[Eg :- www.moviescope.com/viewprofile.aspx?id=1]

Its Sam Profile.

www.moviescope.com/viewprofile.aspx?id=2

Its John Profile

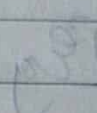
www.moviescope.com/viewprofile.aspx?id=3

Its Kety Profile

• Question → To find Kety profile mail address.

Ans → No I have changed the id directly to know the Kety mail address. I changed id so to go to Kety Profile & see the mail address of it.

3*) OWASP ZAP

- ① Open OWASP ZAP application
- ② Click on 
- ③ Put the URL on URL to attack
- ④ Check Spider, Active Scan & Alerts
- ⑤ In Alerts Red flag are main detection of vulnerability.
Yellow flag are medium vulnerability.

→ Post method include login in, deleting, updating a profile (This are sensitive info)

→ Get method include viewing a profile, typing a message, searching (This are not sensitive info)

En Exam

Just We have to write which method was there like in alerts we got

① Alerts → SQL injection →
POST OR GET.

② do mention only POST or GET in the answer i.e we have to type only which method was there.

10/11/2020

① After the request

② It is not for the request

③ (Note: the path which we use for processing)

④ (Note: the packets will be captured from the network)

⑤ (Note: the packets will be captured from the network)

⑥ After the request is successfully sent the response

⑦ (Note: the packets will be captured from the network)

10- WIRESHARK

→ Wireshark helps us to analyze all packets. It also used by the security professionals.

→ Steps:-

- ① Open Wireshark
- ② It is ask for Ethernet or WiFi
- ③ Choose the path which we use for browsing. (choose the network)
- ④ Directly the packets will be capture from that network.
- ⑤ login to [testphp.vulnweb.com/login.php] from browser & the wireshark capture should be ON.
- ⑥ After login is successfully stop the capturing

★ Now in Exam the 3 question Related to Wireshark should be.

Q17) pcap file for dos - Identify attacking ip.

Ans) ① for finding the Identify attacking IP we have been already given a file

dos.pcap [File given already]

② Open the file given in the ~~PC~~ Computer.

③ After opening the file. the ~~source~~ destination is our IP & the source is the target IP.

④ i) ~~open~~ ^{Click} Statistics option.

ii) Click on IPv4 Statistics.

iii) Then Click Source and Destination addresses.

iv) On Display Filter write down $tcp.flag.syn == 1$ and $tcp.flag.ack == 0$
[Command mention in github]

v) After pressing Enter we can see total packets from which IP & send to which IP.
See Source IP & Destination IP.
[The target IP will be in Source]

which most no. of packets send J.

Q.2] Pcap file for ddos - identify total attacking machine.

Ans) Same as [Ans 1] does steps. Just in final conclusion there will be more different I.P with most packet send to destination I.P.

do mention those I.P machine as DDos attacking machine.

Q.3] Pcap file for login credentials - username and password.

Ans) ① After visiting the site ; login in & then we saved the file in the document folder. [Wireshark file containing data]

② Open the file [name as login to easily get]

③ The file will be already given In the P.C

① So just open the file

② By copy the command or Type `http.request.method == POST`

③

④

Refer steps of Wireshark

③ Paste the command on Apply a display filter & Hit enter.

④ One link will be shown in Wireshark

① So just click on it:

① Go to last by scrolling -

② In the right hand side, we will see
[uname = test & pass = test]

② Another way we can do it as:

① Right click on the link shown in Wireshark

② Go to follow → TCP stream

③ We can see

[uname = test & pass = test]

Refer steps
of
Wireshark

HS/0.0.0.0:8080 → 192.168.1.100:8080

Use search
and select filter

HS/0.0.0.0:8080 → 192.168.1.100:8080

[0288 uninit bag sp2 jlt
90 linker uninitaker shab or
0288 uninit bag jlt]

- How to transfer ~~Peron~~ file from one server to another server (kali to Parrot Eg)

11 = SAMPLE QUESTION PAPER

Q-1) After discovering that a website hosted on a server was vulnerable to blind SQL injection attacks during a security assessment, it was determined that the database management system underlying the site was MySQL. Can you identify the operating system of the machine hosting the database?

Ans) It is just simply asking for ^{Identity} machine I.P or port in which MySQL is open.
In question paper the Subnet would be mention.

Solution = ① Use
• nmap -sV 172.16.0.0/24

OR

• nmap -A 172.16.0.0/24 [gives all info in one but takes time]

[MySQL port number is 3360.
To check whether which IP is
containing port number 3360]

(2) After That

Type `nmmap - O` [IP containing MySQL]

It will give all the information related to operating system.

Q.2/ In an organization's network security assessment, a peculiar Domain User account was discovered to have been added to a machine with the IP address 192.168.1.10. The following user accounts were found to be secure: John Doe, Sarah Connor, Neo, Oracle and Sherlock. What is the username of the suspicious account? Please provide the username only and exclude the domain name.

Please note : Username - JohnDoe; Password - sunshine789

Ans/ ① first connect to the RDP
(with I-P provided & Username
and Password)

② After connecting to RDP need
CMD in that Desktop.

③ After opening CMD use command
ipconfig (To check ip)

④ After that use command
net user

⑤ It will display all the
accounts the mention accounts will
be there so we will note as
valid account &
The account which is not mentioned
in question is known as
attacker account.

Q.3/ John, the network administrator, was performing a routine security scan when he noticed that a machine on the network had a port open for establishing Windows remote desktop connections. He needs to identify the IP address of the machine in question. Can you assist John in locating the IP address of the machine?

Ans / Solution :-

① After scanning the network in Q1 look at the IP and there you would find one with the port 3389 open. The port is for RDP.

OR

② `nmap -Pn -p 3389 [IP]`

Q.4) The "Ethical Hacker-1" machine has a file called `try-DES (ECB) - FTP - IP.here`, containing encrypted credentials to connect to an FTP server. The file's encryption algorithm is DES (ECB). To proceed, the file needs to be decrypted to obtain the FTP credentials. Afterward, use the FTP login credentials, "Hacker" as the username, to connect to the FTP server and retrieve the file named `flag.txt`. Can you decrypt the file & provide the contents of `flag.txt` as the answer?

Ans) Solution:-

- ① Open **Cryptool**.
- ② Open the **file** in the Cryptool.
- ③ Select **Encrypt / Decrypt** option shown in the terminal.
- ④ Select **Symmetric (modern) > DES (ECB)** options to get the data/info of the file containing; by clicking **decrypt** option.
- ⑤ After getting the **data** from the file. Now open **CMD** type **ftp IP**.

⑥ After connecting to the FTP it will ask for username & password. Type the data shown for username & put the password which is got from the file.

⑦ After typing username & password. Next we have to type
get .flag.txt

⑧ After typing that command we will get the contents of the txt file.

Q-57 In an organization, it has been discovered that an employee stole critical bank credentials and concealed them within a file called "Secret - Accounts .txt" using steganography. Fortunately, the email attachment containing the file was seized and saved on the "Ethical Hacker - 1" machine. Your task is to decipher the concealed information in the file and locate the account number. The file is stored at C:\Users\Del\Documents\Snow\Secret - Account.txt and the password required to access the file is "magic". Please enter only the numeric account number in your response.

Ans 7 Solution:-

① Use Snow tool.

7) An file called "SecretHash.txt" has been uploaded via DVWA at <http://192.168.1.10:8080/DVWA>. The file is located at the following path:
C:\wamp64\www\DVWA\hackable\uploads\Secret-Hash.txt. Your task is to crack the MD5 hash present in the file and reveal the original message. You can access the file by logging into DVWA using the provided credentials:

Username - "superuser" and Password - "superman".

Hint: You can decrypt the hash using the following link:
<https://hashes.com/en/decrypt/hash>.

Ans) Solution :-

① Go to website

<http://192.168.1.10:8080/DVWA/>

[mention website in the question]

② Go to the path mention in the website but first put the username & password asked while login

[Username & password mention in the question path also mentioned in the question]

③ The path should be `http://192.168.1.10:8080/DVWA/hackable/uploads/`

④ go to the hashes.com to decrypt the MD5 found in the file.

Q.8) As an ethical hacker working for a company, you have been tasked with retrieving a critical file named "Secret.txt" that has been concealed within the server 2019 machine. The file is located at the following path: `C:\Users\Dell\Documents\Confidential`. You will need to use a backdoor installed in the server to access the file. Your objective is to find the secret number hidden inside the file and provide it as your answer.

Ans) Solution:-

They're just making things complicated by mentioning "2019 machine", "backdoor".

So just do the following things mention below:-

- ① Use credentials of RDP you found in Q2 to login (or any RDP question in your case)
- ② Browse to the mentioned path `C:\Users\Dell\Documents\Confidential`
- ③ Open "Secret.txt" file and copy the number inside.

Q. 9/ During a security assessment, it was discovered that a machine on a network was being targeted by a denial-of-service attack. An network session file named "DOS.pcapng" was recorded and saved in the Documents folder of the Ethical Hacker-1 machine. Your task is to identify the IP address of the attacker's machine.

Ans/ Solution:-

Watch Wireshark section.

Q. 10/ Cynthia, a security researcher, has been investigating unusual network activity on a company's network. She discovered a massive influx of incoming traffic from various sources and determined that the network is under a Distributed Denial of Service (DDoS) attack. The captured network session file, named "DDoS.pcapng," has been saved to the Documents folder of the company's server. Your task is to analyze the file and determine the number of machines that were involved in the attack.

Ans/ Solution:-

Watch Wireshark section.

Q.11/ In FTP site is hosted on a machine in a network. Crack the FTP credentials to obtain the file "flag.txt" available on the FTP server and enter the content in the file as the answer.

Ans/ Solution :-

- ① Find the all IP's present in there also find ports which are open with port no. 21 in the server.

[FTP port no = 21]

- ② Use command

```
hydra -L /home/attacker/Desktop/CEH-TOOLS/Wordlists/Username.txt -P /home/attacker/Desktop/CEH-TOOLS/Wordlists/Password.txt ftp://10.10.10.10 [IP]
```

OR

If in question mention about the "user" then write this command.

- ② `hydra -l user -P password.txt ftp://10.10.10.10 [IP]`
[If username is given]

[Use password.txt only if we use hydra on the same directory ; if not then use whole /home/attacker/Desktop/CEH-TOOLS/Wordlists/Password.txt]

③ get flag.txt

Q.13

Q.12/ An employee named John encrypted a sensitive legal contract and took a backup of it. He then deleted the encrypted file but forgot to delete the original one. He has stored the document on the Desktop of his office computer. John approached you to remotely access his workplace computer, delete the file and provide the document number that starts with "F/NXXXXXXXXXXXX". The computer's name is "Server 2019", and the login credentials are Username: John; Password: Secure123

Ans/ Solution: -

① Scan the subnet with the help of Nmap scan & check which IP is running server 2019 [mention the IP in notepad or

export in .txt file

② Go to RDP put the IP which was found running server 2019 & put the Username & password in it.

③ Then go to view the file in the Desktop of the RDP.

Q.13) You are Lathic, an ethical hacker working for a Movie Production house. While testing the website "www.moviescope.com" for vulnerabilities, you came across an SQL-injection vulnerability. The cookie information is stored in a text file in the Documents folder of the "Ethical hacker-2" machine. Use the SQL DSSS attack method to capture the session link. Determine the contact number of Kety associated with the website.

Ans) Solution:-

Method 1 (bit complicated)

SQL DSSS attack is done with the automated tool like sql map.

[SQL DSSS works like directly dumping the Data & finding the Kety Number]

This method would be a bit complicated if we doesn't familiar with SQL injection. but if we still wanted to use SQL Map then go to github repository & copy the command & use it.

export
in .txt file

password

Method 2 (Easy Method)

- ① Watch the SQL Injection Videos.
- ② Use bypass Authentication, then use 100R to find Kety's number.

Q.14) As part of his job, Raven, a network security specialist, was tasked with analyzing a packet capture file called `Doc.pcapng`, which was stored in the Documents folder of the "Ethical Hacker - 1" machine. He was instructed to determine if any user credentials associated with the website `www.industry.com` were recorded in plain text format. After examining the file, Raven discovered that the site traffic was traversing in plain text and found a username and password recorded in one of the packets. Please provide the credentials found in the capture file in the following format: Username/Password.

Ans) Solution :-

① Watch Wireshark section

② Use command `http.request.method == POST`

Q.15) As an ethical hacker working for a movie production company, you have been tasked with testing the website "www.moviescope.com" for vulnerabilities. After conducting your tests, you discovered that the website is vulnerable to SQL injection attacks. To determine the type of HTTP method that poses the highest risk to the website, you decide to use the OWASP ZAP tool. The tool will help you identify and exploit the SQL injection vulnerability to determine which HTTP method poses the highest risk to the website.

Ans) Solution :-

① Watch the OWASP ZAP video in SQL injection section

[The Answer would be GET or POST Method]

Date _____
Page _____

Q.16) After scanning the network, you are ethical hacker found out that some hosts are alive, identify the number of hosts that are alive.

Ans) Solution:-

Look at the scan results of Q1

or we can use this command

`nmap -sn 192.168.9.0/24`

[As this only checks whether host is up or not]

Q.17) You're working as an ethical hacker in a company where an employee has stolen trade secrets and encrypted them using Veracrypt. The Veracrypt volume file named "Secret" is saved on the Ethical Hacker - 1 machine's Desktop. The password to the file was discovered in one of the employee's emails during an investigation. Your task is to decrypt the file using the password "test" and identify the secret code contained in it.

Ans) Use Veracrypt [Watch Veracrypt Video in Cryptography section].

Q.18) As an ethical hacker working with a bank, your task is to decrypt a cipher file named "Cry-RC4-Accountno.txt" stored in the Documents folder of the Ethical Hacker-1 machine. The file was encrypted by an attacker who stole a customer's account number from the bank's database using Cryptool. Your goal is to determine the account number by decrypting the file, with a hint to use "14" as the key-value under the key length.

Ans) Solution:-

- ① Open Cryptool.
- ② Click On Encrypt / Decrypt.
- ③ Then Click On Symmetric (modern) then RC4.

[RC4 mention in the Question]

- ④ Change the Key value under the Key length from 00 to 14.

[14 mentioned in the question as Key value]

③ do connect [use adb connect]

[use adb connect then the I-P Then(:) then the port]

④ After connected type adb shell. Browse check the sdcard & read the file which contains secret information.

Q-20) A vicious attacker has exploited a vulnerability in a machine on a corporate network and encoded the IP address of the target machine. The encoded file was discovered by the vigilant database administrator during a routine audit of the database. The encoded data is located in the file "Encoded data.txt" on the Desktop of the Ethical Hacker - 1 machine. Your task as an ethical hacker is to decode the file and extract the IP address of the compromised machine. The security of the entire corporate network depends on your success. (Password: shadow123)

Ans) Solution:-

Use BCTextEncoder (Or Watch its Video)

* New Topics

Things we would cover in this section:

- ① FQDN
- ② Wi-Fi password cracking
- ③ SMB password cracking
- ④ Detect & Analyse IOT traffic Wireshark
- ⑤ Image Steganography
- ⑥ Command Execution
- ⑦ SQL map
- ⑧ Privilege escalation

TOPIC 1 :- Fully Qualified Domain Name [FQDN]

Q) What is FQDN?

Ans) ① FQDN stands for Fully Qualified Domain Name. It is a complete and specific name that uniquely identifies a domain on the internet.

② As FQDN includes the hostname (the specific name of a device or server) and the domain name (the broader organization or network the device belongs to).

• FQDN = Hostname + Domain

• FQDN = mail . example . com

* > Finding FQDN

We can go to Settings check out the About PC Section.

We can get FQDN by checking the Workgroup or Domain Section.

Like :-

Type 1 (Example)

① Full computer name : - DESKTOP-ABZRB4C

Workgroup : WORKGROUP

★ There are two types of FQDN.
FQDN can vary depend on the environment.

Type 1 : - (Work GROUP Environment)

The ① is Type 1 Group.

In this Group the computer connected without centralized domain controller.

~~Type 2~~ typically consists of without Domain Name. In work group Environment we see shorter names extensions.

Type 2 : - (Computers are connected to Domain Environment)

In this environment computers are connected to ^{windows active} directly domain. The full computer name includes Domain Names as well as shown in the below type

Domain name → Full computer name : SSC.SUPER.COMP.adb.ssc.wisc.edu

Computer name : SSC(SUPER.COMP)

This is the Host name.

* So FQDN is consists of HOSTNAME + DOMAIN NAME

Eg:- ads.ssc.wisc.edu (1)

TYPE 2 (Example)

Computer Name: SSCSUPERCOMP (2)

Full Computer name: SSCSUPERCOMP.ads.ssc.wisc.edu

Controller.

Computer Description:

Domain: ads.ssc.wisc.edu

Environment)

→ In Exam we have to solve FQDN
with the help of NMAP
[They will not mention about NMAP
but we can use it]

edu

FINDING PGDN USING NMAP

① Make a Target List which are alive in the subnet.
[Taught in the Previous Video]

② Use Command `nmap -p389 -sV -iL <target-list>`

-sV = Version

-iL = Importing a List

-p = port

port 389 = Port 389 is associated with Lightweight ~~access~~ directory access Protocol (LDAP) Service.

Whenever we see port 389 while scanning network then we see services related to LDAP.

LDAP is actually a Protocol it is used for accessing & maintaining directory info like users accounts within a network. It is commonly used for managing user accounts, authentication, access control etc on a network.

How → We might think how LDAP is connected to Domain Controller.
LDAP is connected to Domain Controller
as in the question it was asked ~~How~~ ~~the~~
You have to find the FQDN of a Domain Controller in a Subnet.

How → So how the port 389 & LDAP service is connected to Domain Controller.

Q) What is Domain Controller

Ans) A Domain Controller is a Server in a Windows Based Network which manages Security Policies, User Authentication & Directories Services.

So it plays a Central Role in Infrastructure of Active Directory i.e. which is service provided by Microsoft.

How → How the port 389 & LDAP service is related to Domain Controller.

Ans) ① Port 389 is a Default port which is used by LDAP service which is a key component of active directory.

② Domain Controller runs the LDAP Service typically on the port 389 to handle LDAP communication with clients.

So in Summary.

The LDAP Protocol helps the clients & the Domain

Controller exchange directory related data & performs operation like querying, modifying or adding entries to the directory.

So the Port 389 acts as an Communication channel for this LDAP traffic between the Client & the Domain Controller.

Use Command [Only when we know the IP has open port 389]

`nmap -p389 -sV <target-IP>`

After using anyone Command we get output such as :-

In Output it will mention out:

PORT STATE SERVICE VERSION

In the VERSION SECTION it will be mention about Domain like eg: Domain: pentester.team & Below that

Service info will be mention like eg: -

Service info: Host: DC; OS: Windows; CPE: ipr18.microsoft

Windows

As per our meeting - 28.07.2017

Agenda will be $Agenda = DC - \text{pentester-team}$

[Prop the already will be given in the machine]

By using the above command, we will work the WPA key

2. Back a WPA2 network and decrypting

Disturbance - as per [pentester-team] WPA2 key for [WPA2]

1. In the technique we will use the technique

Agenda = 2

to inform to pentester team to work the

Best is to use the WPA2 key

for WPA2 key, it will be provided the

key to the machine

TOPIC 2 :- Hacking Wireless Networks

1. Crack a WEP network using Aircrack-ng *

aircrack-ng [pcap file]

[Pcap file already will be given in the machine]

By using the above command aircrack-ng will crack the WEP Key. *

2. Crack a WPA2 network using Aircrack-ng.

aircrack-a2 -b [Target SSID] -w [password-Wordlist.txt]
[WPA2 PCAP FILE]

-a is the technique used to crack the handshake,

2 = WPA technique

-b refers to bssid; replace the with the BSSID of the target router

-w stands for wordlists; provide the path to a wordlist!

(In both the file conditions we have to drag & drop so we don't have to write the command).

★ Method 2

◆ If the above Method 1 (Drag & drop) don't work then Try Method 2

① Copy the BSS ID.

② Then paste the command.

aircrack-ng -b [bss id] -w [drop the wordlist file] [drop the .cap file]

★ For finding the BSSID

① Open the Terminal

② Type the Command

aircrack-ng [Drop the .cap file]

③ Press Enter - It will give BSSID, ESSID & Encryption.

BSSID = Basic Service Set Identifier.

ESSID = Extended Service Set Identifier.

SSID = Service Set Identifier.

TOPIC 3 = Android Hacking [Updated]

Q. An Insider attack has been identified in one of the employees mobile device in 192.168.0.0/24 subnet. You are assigned to covertly access the users device and obtain malicious elf files stored in a folder "scan". Perform deep scan on the elf files and obtain the last 4 digits of SHA 384 hash of the file with highest entropy value.

Ans / Solution :-

Elf = Executable & linkable format
[Typically its like a docx, pdf, ~~extensions~~ extensions like format]

Steps to follow

- ① Open the terminal.
- ② Type Command `adb connect [I.P]:5555`
- ③ Type Command `adb shell`
- ④ Find the folder mention in the question (i.e scan)
- ⑤ If not found check in the `sdcard` [Type cmd `cd sdcard`]
- ⑥ After `cd sdcard` then type `ls` then `cd scan`.

- (7) Then after od scan again type ls
- (8) We will see 3 files all are elf extension.
- (9) So we have to move out the 3 elf extension file to desktop/VM
- (10) do we come back by command cd ..
- (11) Then type command adb shell >
cd /sdcard/scan/ > pwd
- (12) Here we will get [/sdcard/scan] path.
- (13) Type exit command.
- (14) Then type command sudo -i
[TO become root user]
- (15) Type command adb pull /sdcard/scan
- (16) Then type ls
- (17) For getting an entropy value we ~~would~~ have to like a tool

i.e ent.
[If available then type ent in terminal
if not then download by entering
apt install ent]

* Note: - Entropy means which password or number are easily guessable are known as low entropy & which are not are known as High entropy.

Eg: - 1234 - low entropy

\$2323 agss6 x \$1. @fdhk = High Entropy.

(18) We will check all the files [3 files]
[for eg:- evil.elf, evil2.elf, evil3.elf]

(19) do type command `ent evil.elf,`
`ent evil2.elf, ent evil3.elf`.

[In these we will check which files has most entropy] [for eg `evil.elf` has]

(20) Atlast we will type command to know the last 3 SHA value i.e
`sha384sum evil.elf`

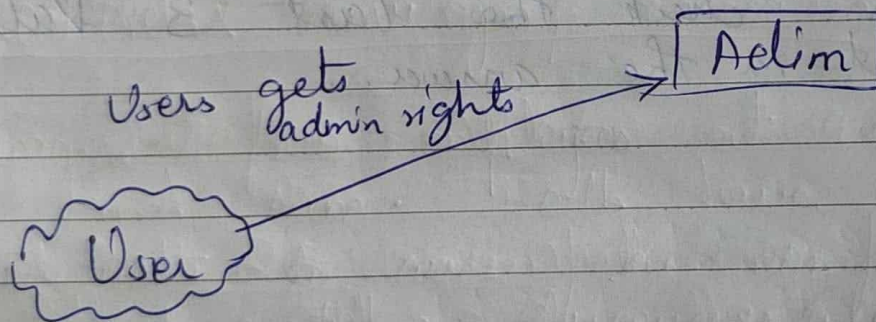
(21) Then check the last 3 value & put in the answer.

Date _____
Page _____

TOPIC 4 = Simple Privilege Escalation

Q. What is Privilege Escalation?

Ans. Privilege Escalation happens when a malicious user exploits a bug, design flaw, or configuration error in an application or operating system to gain elevated access to resources that should normally be unavailable to them.



TYPES OF PRIVILEGE ESCALATION

① Horizontal Privilege Escalation:

This occurs when a user gains unauthorized access to another user's account at the same permission level. It's like exploiting a vulnerability to switch to a different account with equal privileges.

② Vertical Privilege Escalation:

This type involves elevating one's own privileges to a higher level. It often means taking advantage of a vulnerability to move from a lower-level account to a higher-level account, such as from a standard user to an administrator.

③ Local Privilege Escalation:

Local Privilege Escalation happens when a user exploits a vulnerability to gain higher privileges within a specific context or area of the system. It doesn't affect the entire system; instead, it grants additional access within a certain scope.

④ Remote Privilege Escalation :

Remote Privilege Escalation occurs when a user exploits a vulnerability from a distance, typically over a network. By leveraging this vulnerability, the user gains higher privileges on the target system without physical access.

Examples :-

① Horizontal Privilege Escalation :

Imagine two employees at example.com, John and Sam. Both have regular user accounts to access the company's internal website. John discovers a way to use Sam's account without a password. He can now access the same parts of the website that Sam could access, but he hasn't gained any extra privileges.

② Vertical Privilege Escalation :

John, a regular employee at example.com, finds a security flaw in the company's email system. By exploiting this flaw, he tricks the system into treating his account as an administrator's account. Now he,

can access confidential company emails and change email settings that only administrators should be able to access.

③ Local Privilege Escalation:

Let's say you're on example.com's website, and you notice that the website's login form has a hidden input field that isn't properly secured. Through this vulnerability, you're able to inject some code that tricks the website, it gives you access to admin-only features and information, but only within the scope of that website.

④ Remote Privilege Escalation:

Suppose you discover a weakness in example.com's server configuration. The server has an outdated software component that is known to have a security vulnerability. Using this vulnerability, you remotely send a specially crafted request to the server. Because of the vulnerability, the server executes your code with higher privileges than you should have, granting you unauthorized access to sensitive data or administrative functions on example.com's systems, even though you're not physically on their network.

Q) You used shoulder surfing to identify the username and password of a user on the Ubuntu machine in the 192.168.0.0/24 network, that is Kali and pass@123. Access the target machine, perform vertical privilege escalation to that of a root user, & enter the content of the imroot.txt file as the answer.

Ans / Solution:-

① Use the nmap Command

nmap -sV -p 22 192.168.0.0/24

Check Port 22 is open or not.

We will give this command to check all the I.P in the subnet which has port 22 open or not.

∴ We have to check which I.P is alive & in that alive I.P's does port 22 is open or not.

Note: We have already given Username, Password & IP just we think of that we can get easily SSH connection.

② Giving ssh command to connect to it.

`ssh kali@192.168.0.1`

After giving this command it is ask you password.

Then Enter the password i.e `pass@123`

③ After that we have to give this command.

`sudo -l`

[It will tell you what are the following commands which we can run after ~~the~~ you get the elevated privileges. i.e after becoming root] Basically is not generally necessary. So we move to next step.

The Next command is

`sudo -i`

After this command check whether we are root user or not so give command.

`whoami` [It will give root as answer]

After that we change the directory to [/]

to at then `cd /`

After that we have to find `imroot.txt` file location so we will give command.

~~find~~ `find -name imroot.txt`

[It will give path as the output]

After that we have to check what contents are there in the `imroot.txt`.

`cat /home/kali/Documents/imroot.txt`

It will show all the contents of
txt file.

TOPIC 5 = CVE, CVSS & NVD

Q/ What is CVE?

Ans/ ① Definition: CVE (Common Vulnerabilities & Exposures) is a standardized naming convention used to uniquely identify and track vulnerabilities in software & hardware.

② Purpose: The primary purpose of CVE is to provide a standardized and common way to refer to vulnerabilities, making it easier for security professionals, researchers & organizations to discuss and share information about vulnerabilities.

③ Format: A CVE entry includes a unique identifier (e.g. "CVE-2021-12345") along with a brief description of the vulnerability.

④ Usage: CVE entries are used in vulnerability databases, security advisories, and other sources to provide a reference point for vulnerabilities. When a security issue is identified, it can be assigned a CVE identifier to ensure a consistent reference across the industry.

Q/ What is CVSS?

- Ans/ ① Definition: CVSS (Common Vulnerability Scoring System) is a framework used to assess and communicate the severity of security vulnerabilities based on a standardized set of metrics.
- ② Purpose: The primary purpose of CVSS is to provide a quantitative and qualitative way to evaluate the impact & risk of a vulnerability, helping organizations prioritize their response & mitigation efforts.
- ③ Metrics: CVSS assigns scores to various metrics, including the exploitability of the vulnerability, the impact on confidentiality, integrity, and availability, and other factors.
- ④ Score: A CVSS score (ranging from 0.0 to 10.0) is calculated based on the assigned metrics. The score helps organizations understand the potential impact of a vulnerability & make informed decisions about how to address it.
- ⑤ Versions: CVSS has gone through different versions (e.g., CVSS v2 & CVSS v3.0), each with improvements and refinements to better reflect the complexity of modern vulnerabilities.

Q? What is NVD?

Ans) NVD (National Vulnerability Database) is a repository of information about vulnerabilities maintained by the U.S. National Institute of Standards and Technology (NIST).

② It aggregates vulnerability information from various sources & assigns CVE identities to vulnerabilities.

ity. ③ NVD provides detailed information about vulnerabilities, including CVSS scores, technical details, impact assessments & links to relevant resources.

④ NVD serves as a central resource for security professionals to access comprehensive information about vulnerabilities.

Q? What is EOL?

Ans) The "End of Life" (EOL) of a web development language platform refers to the point in time when the platform is no longer actively maintained or supported by its developers or the organization behind it.

During the EOL phase, the platform ceases to receive updates, bug fixes, security patches,

and new features. This lack of ongoing support can lead to various issues, including security vulnerabilities and compatibility problems.

Example: -

IS PHP 5.6 EOL?

→ As of Dec 31st, 2018, PHP 5.6 also reached its end of life.

This means PHP 5.6 is no longer been updated by PHP Teams with respect of bug fixes, updates, security purposes patches release etc.

Suppose you find any vulnerability related to 5.6 & you send the report you will get assign with CVE score but there is not prefix as it has come to End of Life (EOL)